

Universidad Mayor de San Andrés
Facultad de Ciencias Puras y Naturales
Carrera de Informática



INFORME PENTESTING

Semestre I/2026

Estudiante: Riveros Vera Angeles Sarai

Materia: Taller Técnico Superior

Docente: Lic. Brigida Alexandra Carvajal Blanco

Fecha: 19 de Mayo de 2026

Versión 1.0

La Paz - Bolivia

1. Resumen ejecutivo

El presente informe describe el proceso de evaluación de seguridad realizado sobre el sistema web “Pet Spa Grooming”, desarrollado por el estudiante Ivan Omar Limachi.

La evaluación tuvo como objetivo verificar el cumplimiento de controles básicos de seguridad relacionados con autenticación, validación de formularios, gestión de sesiones y control de acceso.

La revisión fue realizada exclusivamente mediante el análisis de una demostración en video proporcionada por el estudiante desarrollador, sin acceso directo al código fuente, servidor, base de datos ni entorno de ejecución. Debido a ello, las observaciones y conclusiones presentadas en este informe se basan únicamente en las funcionalidades evidenciadas durante la demostración audiovisual.

Durante la evaluación se evidenció la implementación de mecanismos de seguridad como hashing seguro de contraseñas, auditoría de acciones, bloqueo temporal de cuentas e implementación de contraseñas temporales para empleados. Asimismo, se identificaron aspectos que podrían fortalecerse para mejorar la seguridad general del sistema, especialmente en autenticación multifactor y expiración de enlaces de activación.

2. Alcance de la prueba

Elemento	Descripción
Sistema objetivo	Sistema Web Spa de Mascotas
Tipo de sistema	Aplicación web
Tecnologías identificadas	PHP
Módulos evaluados	Login, registro de usuarios, gestión de sesiones y control de acceso
Funcionalidades revisadas	Activación por correo, bloqueo de cuentas, hashing de contraseñas, auditoría
Periodo de evaluación	12/05/26 al 19/05/26
Responsable del sistema	Nina Limachi Ivan Omar
Evaluator	Riveros Vera Angeles Sarai
Evidencia analizada	https://www.youtube.com/watch?v=C_ozaWGDvCQ

3. Metodología utilizada

La metodología utilizada aplicada estuvo basada en observación funcional del sistema mediante una grabación de video proporcionada por el estudiante desarrollador. No se ejecutaron herramientas automatizadas de escaneo, explotación de vulnerabilidades ni pruebas directas sobre infraestructura real.

3.1. Recolección de información

Durante la demostración se identificaron los siguientes controles de seguridad:

Control observado	Estado
Registro libre de clientes	Implementado
Registro manual de empleados	Implementado
Activación por correo electrónico	Implementado
Seguridad de contraseñas	No evidenciado completamente
Medidor de fuerza - Contraseñas	Se evidenció las instrucciones más no la indicación de cumplimiento
Email de Activación	Implementado
Expiración de enlaces de activación	No evidenciado
Bloqueo por intentos fallidos	Implementado
Hashing seguro de contraseñas	Implementado
Auditoría	Implementado
Borrado lógico	No implementado
Autenticación 2FA	No implementado
Inicio de sesión/continuar con Google	No implementado

3.2. Observaciones adicionales

- El sistema utiliza contraseñas temporales generadas automáticamente para empleados.
- El sistema no obliga a cambiar la contraseña temporal al usuario en su primer inicio de sesión.
- La cuenta se bloquea temporalmente durante 15 minutos tras múltiples intentos fallidos de autenticación.
- No se evidenció implementación de autenticación multifactor (2FA).
- No se evidenció expiración de enlaces de activación por correo.
- No se observó integración con inicio de sesión mediante Google.

- No se evidenció implementación de borrado lógico de registros.

4. Hallazgos encontrados

Código	Observación	Módulo	Riesgo	Descripción	Recomendación
V-01	Ausencia de autenticación 2FA	Login	Medio	No se evidenció autenticación multifactor durante la demostración	Implementar autenticación multifactor
V-02	Expiración de enlaces no implementada	Activación	Medio	No se observó expiración de enlaces enviados por correo electrónico	Implementar expiración automática de enlaces de activación
V-03	Inicio de sesión con Google no implementado	Login	Medio	El sistema no cuenta con autenticación mediante proveedores externos	Considerar integración futura con Google OAuth
V-04	Borrado lógico no implementado	Gestión de datos	Alto	No se evidenció mecanismo de eliminación lógica de registros	Realizar una demostración más profunda para corroborar este punto.
V-05	Validación limitada mediante video	General	Bajo	Algunas configuraciones internas no pudieron verificarse directamente	Realizar pruebas técnicas directas en futuras evaluaciones

Las vulnerabilidades encontradas fueron clasificadas según su impacto.

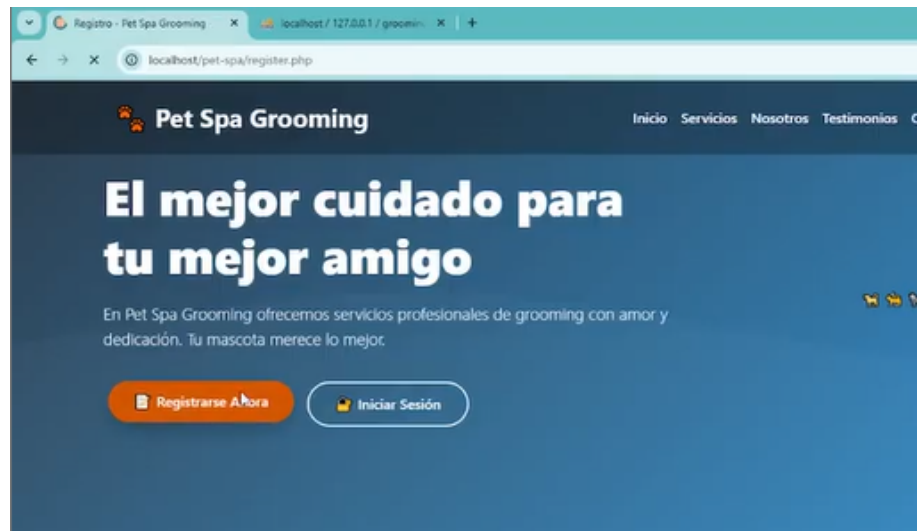
Nivel	Descripción
Alto	Vulnerabilidades que afectan la seguridad crítica
Medio	Riesgos explotables bajo ciertas condiciones
Bajo	Riesgo de seguridad baja

5. Evidencias

Las evidencias obtenidas corresponden únicamente a capturas extraídas de la demostración en video proporcionada por el estudiante que desarrolló el sistema.

Durante la evaluación se observaron las siguientes funcionalidades:

- Inicio de sesión.



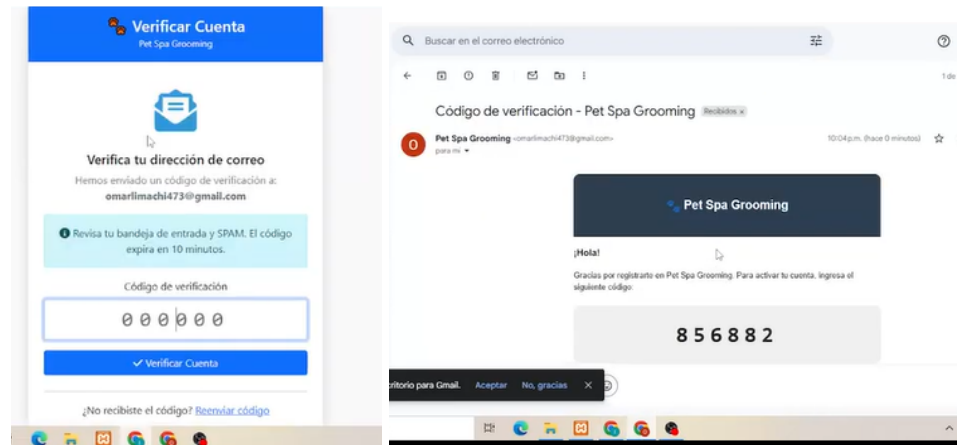
- Registro de usuarios.

Two side-by-side screenshots of web forms. The left screenshot is titled 'Registro de Cliente' and contains fields for 'Correo electrónico *', 'Contraseña *' (with a note: 'Mínimo 8 caracteres, mayúsculas, minúsculas, números y símbolos'), 'Confirmar contraseña *', 'Nombre *', 'Apellido *', 'Teléfono *', and 'Carnet de Identidad'. The right screenshot is titled 'Crear Nuevo Usuario' and contains a message: 'Se generará una contraseña temporal de 10 caracteres. Puedes optar por enviarla por email o entregarla manualmente.' Below this are fields for 'Email *' (filled with 'omarlimachi437@gmail.com'), 'Rol *' (with a dropdown menu showing 'Seleccionar...'), 'Nombre *' (filled with 'Ivan'), 'Apellido *' (filled with 'Limachi'), and 'Teléfono'. At the bottom, there is a checkbox 'Enviar credenciales por email' which is checked, and two buttons: 'Crear Usuario' and 'Cancelar'.

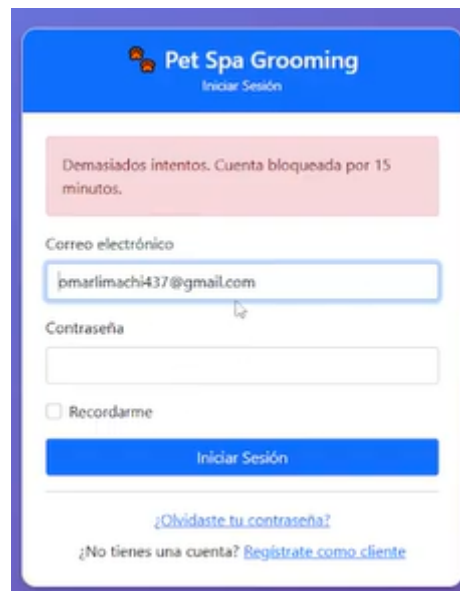
Registro libre cliente

Registro de empleados, solo admini

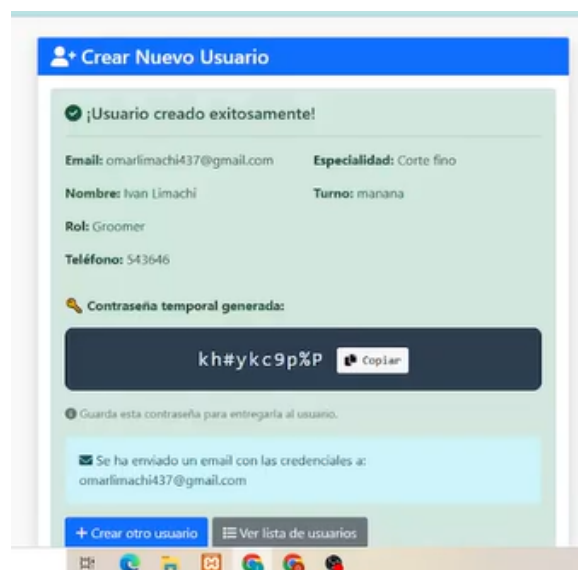
- Activación de cuentas mediante correo electrónico.



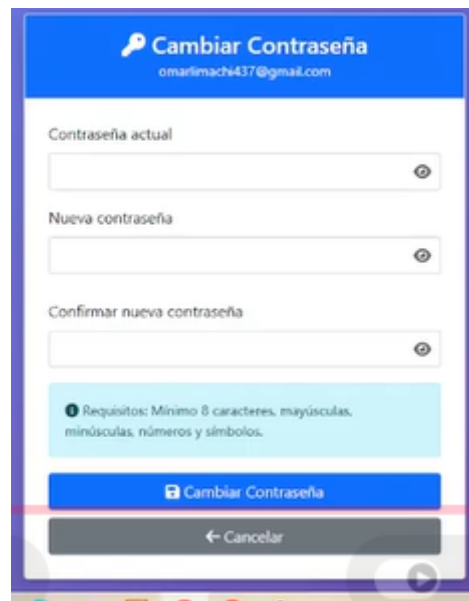
- Bloqueo temporal de cuentas tras múltiples intentos fallidos.



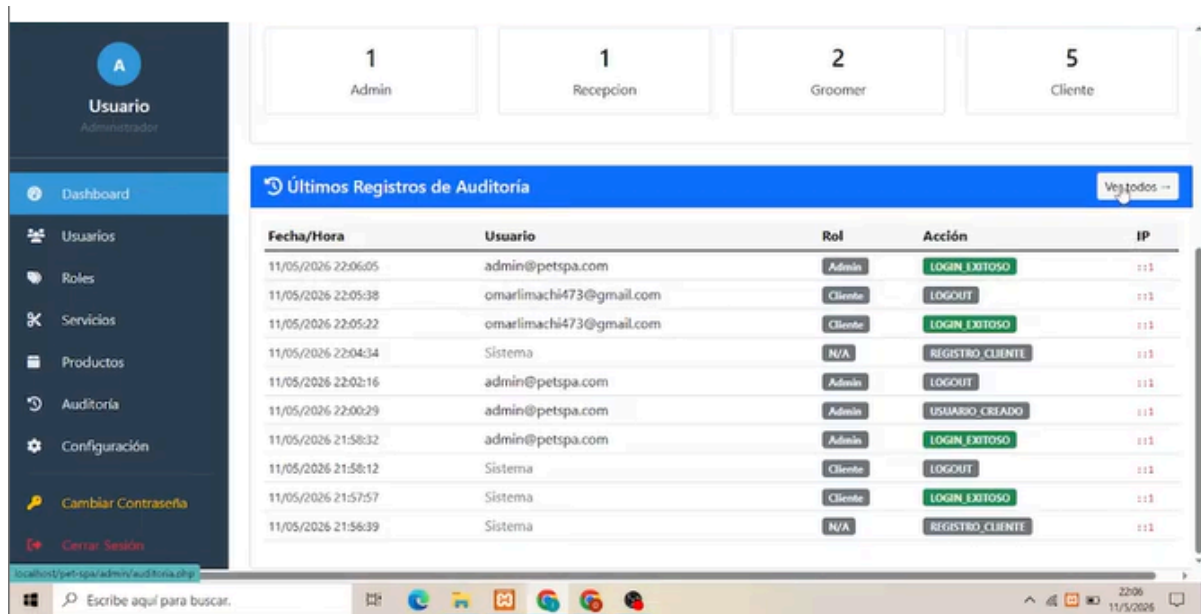
- Generación automática de contraseñas temporales para empleados.



- Cambio obligatorio de contraseña en el primer inicio de sesión.

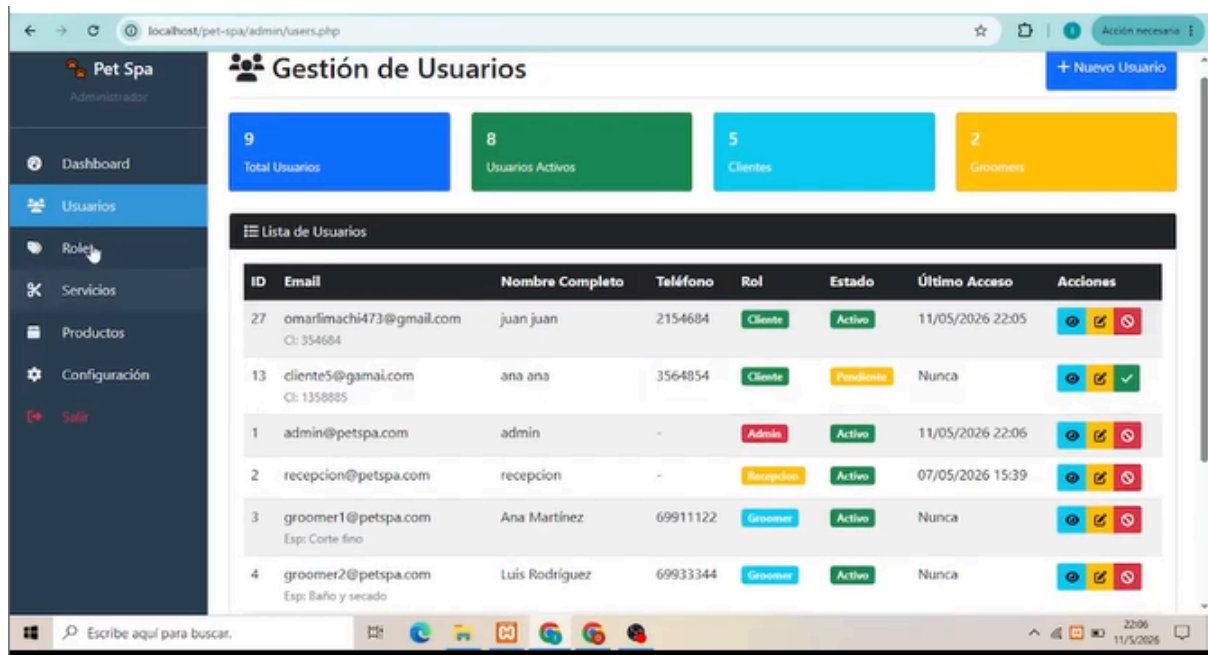


- Registro de auditoría.



Fecha/Hora	Usuario	Rol	Acción	IP
11/05/2026 22:06:05	admin@petspa.com	Admin	LOGIN_EXITOSO	111
11/05/2026 22:05:38	omarlimachi473@gmail.com	Cliente	LOGOUT	111
11/05/2026 22:05:22	omarlimachi473@gmail.com	Cliente	LOGIN_EXITOSO	111
11/05/2026 22:04:34	Sistema	N/A	REGISTRO_CLIENTE	111
11/05/2026 22:02:16	admin@petspa.com	Admin	LOGOUT	111
11/05/2026 22:00:29	admin@petspa.com	Admin	USUARIO_CREADO	111
11/05/2026 21:58:32	admin@petspa.com	Admin	LOGIN_EXITOSO	111
11/05/2026 21:58:12	Sistema	Cliente	LOGOUT	111
11/05/2026 21:57:57	Sistema	Cliente	LOGIN_EXITOSO	111
11/05/2026 21:56:39	Sistema	N/A	REGISTRO_CLIENTE	111

- Gestión de usuarios.



6. Recomendaciones generales

- Implementar autenticación multifactor (2FA).
- Aplicar expiración automática a enlaces de activación enviados por correo electrónico.
- Incorporar HTTPS obligatorio en todo el sistema.
- Pedir el cambio forzoso de contraseña en el primer inicio de sesión.
- Implementar borrado lógico para registros sensibles.
- Mantener políticas seguras de generación y cambio obligatorio de contraseñas temporales.
- Validar datos tanto en cliente como en servidor.
- Mantener registros de auditoría actualizados.
- Restringir accesos administrativos mediante validación estricta de roles.
- Verificar seguridad de sesiones y expiración automática por inactividad.
- Realizar pruebas técnicas directas en un entorno controlado.

7. Conclusiones

La evaluación realizada sobre el sistema web “Spa de Mascotas” permitió verificar, mediante una demostración audiovisual, la implementación de diversos mecanismos de seguridad orientados a proteger la autenticación y gestión de usuarios.

Durante la revisión se evidenciaron controles importantes como hashing seguro de contraseñas, auditoría de acciones, bloqueo temporal de cuentas y uso de contraseñas temporales.

Sin embargo, también se identificaron oportunidades de mejora relacionadas con autenticación multifactor, expiración de enlaces de activación, obligar al usuario a

cambiar de contraseña en su primer inicio de sesión y no así como una opción, además no se evidenció el borrado lógico.

Debido a que la evaluación fue realizada únicamente mediante una demostración en video, no fue posible ejecutar pruebas técnicas directas ni validar completamente configuraciones internas del sistema. Se recomienda realizar futuras evaluaciones técnicas en un entorno controlado para verificar de forma más profunda los mecanismos de protección implementados.